

AppExchange Listing — Other Information

AppExchange Listing — “Other Information”

Field on the Partner Console submission form: *Other Information — Provide any other information that will help us test your solution.*

Submitted for: Portwood DocGen Managed v2.0.0 (04tVx000000ZqBpIAK), 2026-05-22 re-submission

Paste-ready text

The AppExchange Security Review Dev Org is pre-configured for end-to-end testing of v2.0.0. The package is installed, the running user is assigned the DocGen_Admin permission set, and sample data is seeded. The reviewer should not need to do any setup beyond logging in.

Test environment

Item	Value
Test org alias	AppExchange Security Review Dev Org
Username	dave.2a1209f2e79c@agentforce.com
Login URL	https://login.salesforce.com (or use the Partner Console “Log In” link)
Installed package version	v2.0.0 (04tVx000000ZqBpIAK)
Running-user permission set assigned	DocGen_Admin (full CRUD/FLS on all DocGen objects, access to all Apex classes, tabs, pages, LWCs)
Release Update enabled	“Use the Visualforce PDF Rendering Service for Blob.toPdf() Invocations” — required for PDF output

Item	Value
Sample Account	Acme Demo Corp (Industry: Technology, Annual Revenue: \$50,000,000) — used for single-record generation and signature testing
Sample Contacts	3 contacts on the Acme account (Alice Buyer, Bob Approver, Carol Witness) — used for multi-signer testing
Sample Opportunity	1 closed-won opportunity on Acme — used for cross-object merge-tag testing
Sample templates	3 DocGen Templates (Account Summary, Contact Welcome Pack, Signature Request – Sales Contract) each with an active DOCX body

Recommended test scenarios

These exercise every code path that was changed in v2.0 (CRUD/FLS hybrid, guest helper, clickjacking remediation, verifier multi-signer fix) plus the headline features added between v1.56 and v2.0:

1. Single-record document generation (DocGenController.processAndReturnDocument) - Navigate to Acme Demo Corp → click the **Generate Document** button on the page layout - Pick the Account Summary template, choose **Download**, click **Generate Document** - Expected: a merged PDF downloads in the browser. Header has Acme's logo (rendered via a relative /sfc/servlet.shepherd/version/download/... URL), body lists the 3 contacts in a {#Contacts}{Name}/{Contacts} loop, total annual revenue formatted with {AnnualRevenue:currency}.

2. Bulk generation (DocGenBulkController.startBulkJob) - App Launcher → **DocGen** app → **Bulk Generation** tab - Pick the Contact Welcome Pack template, filter Account = Acme Demo Corp, click **Generate Bulk** - Expected: a DocGen_Job__c is created, the batch enqueues, and a combined PDF lands as a ContentVersion on the job record when the batch completes (~30s).

3. Chart engine (the v1.99 feature most likely to surface heap / PNG issues during scan) - The Account Summary template includes a {Chart:Contacts:Department:bar} tag - Generate the doc per scenario 1 - Expected: the PDF includes a real PNG chart (bar style, 8-color palette, anti-aliased) rendered entirely in Apex — no external chart service callout. The PNG is stored as a ContentVersion titled docgen_chart_* and embedded in the HTML via a relative Shepherd URL.

4. Signature flow — multi-signer (DocGenSignatureSenderController.createTemplateSignerRequestWithOrder + guest signing) - On Acme Demo Corp → **Send for Signature** quick action - Pick the Signature Request – Sales Contract template - Add all 3 contacts as signers with roles Buyer, Approver, Witness - Choose signing order: **Sequential** (forces 1 → 2 → 3) - Send - Expected: 3 DocGen_Signer__c records created with unique 64-char SHA-256 hex tokens, 1 email queued to the first signer (Alice Buyer). The other two signers are in Pending status until Alice signs. - **To test the guest-context Schema-CRUD-gate:** open the signing link in an incognito browser, complete the PIN flow (PIN is delivered to a

non-validated address so it won't actually arrive — see Known Limits below for the bypass), type the legal name, check consent, click Sign. Audit record is written via `DocGenSignatureGuestSecurity.assertAuditCreateable(token)`.

5. Verifier — multi-signer (the v2.0 LIMIT 1 bug fix) - Once all 3 signers have completed, the final stamped PDF is generated and emailed to the requesting admin + saved to the Acme record - Open the PDF → it includes a “DocGen Verification” certificate page with a SHA-256 hash and a URL pointing at `/apex/DocGenVerify` - Drag the signed PDF onto the DocGen Authenticator LWC (Command Hub → Authenticator tab) - **Expected (v2.0 behavior):** the verifier shows all 3 signers with their roles, sign dates, IPs, and consent timestamps. **The v1.56 / v1.99 bug** was that only the first signer was shown (LIMIT 1 in the SOQL). - Alternatively, hit `/apex/DocGenVerify?id=<requestId>` directly — the request-Id path was always returning all signers; the hash-drop path now matches.

6. Clickjacking remediation verification (the 4 reviewer findings) - Open the Lightning App Builder → drag the docGenAdmin component onto an arbitrary page - Inspect the rendered HTML — every previously-flagged `<ul class="dg-suggestion-dropdown">`, `<div class="dg-provider-dropdown">`, etc. now wears the SLDS `slds-is-absolute` utility class. No `inline style="position: absolute|fixed"` attributes remain on exposed LWCs. - The same applies to docGenAuthenticator, docGenBulkRunner, docGenQueryBuilder, docGenColumnBuilder.

Known limits / things to be aware of during testing

- **Email deliverability.** The test org's “All Email” deliverability is enabled, but the signing emails go to `@example.com` placeholder addresses (the sample contacts) — the email **is sent** by `Messaging.sendEmail()` but bounces. To exercise the full PIN flow without waiting for an email round-trip, the signer record's `PIN_Hash__c` field is pre-populated with `SHA256('000000')` so PIN `000000` works on every sample signer. This is documented in the seeded-template description field. *(If you'd rather see a real signing email round-trip, replace the seeded signer emails with a real address before invoking scenario 4.)*
- **The chart engine uses Salesforce orgs's CPU time.** A template with 5+ chart tags can take 15-30 seconds per generation on the sample data. This is expected — the chart engine is 100% native Apex (no external service), so all PNG rendering happens inside the Apex governor. The implementation respects all Apex limits and is heap-safe for charts up to ~50 data points each.
- **Async signature finalization.** When the last signer of a multi-signer document completes, the final stamped PDF is generated by a Queueable triggered by a `DocGen_Signature_PDF__e` platform event — this runs as Automated Process user and may take up to 30 seconds to complete after the signing action returns. Refresh the signature request record after that window to see the final PDF attached.
- **Code Analyzer false positives.** 38 Moderate findings remain (0 Critical / 0 High / 0 Low). Every Moderate finding is documented in `DocGen_False_Positive_Report.pdf` with the specific reason it is a false positive: 9 are `pmd:AvoidLwcBubblesComposedTrue` on the recursive `docGenTreeNode` component (composed events are structurally required for the

tree builder); 29 are `pmd:ProtectSensitiveData` on field metadata where the rule heuristically flags any field name containing “Signer”, “Token”, “Hash”, or “PIN” (but in our case these are legitimate signature/audit fields, and the actually-sensitive ones store SHA-256 hashes, not plaintext).

- **SYSTEM_MODE retention on package-internal queries (the v1.56 finding category).** Every retained `WITH SYSTEM_MODE` query / Database.<op>(record, AccessLevel.SYSTEM_MODE) DML in v2.0 is preceded by an explicit `Schema.sObjectType.<Object>.isAccessible|isCreateable|isUpdateable()` check at the `@AuraEnabled / @InvocableMethod` entry point. This is the reviewer’s stated first alternative from the v1.56 finding-resolution language. The reason we cannot use `USER_MODE` directly on these queries is that `USER_MODE` strict-FLS strips package-namespaced custom fields (e.g. `Query_Config__c`, `Header_Html__c`, `Content_Version_Id__c`) when subscriber admin profiles haven’t been granted FLS individually per release — the package-build scratch org reproduces this with No such column 'Query_Config__c' errors that break ~100 tests. See `SECURITY_REVIEW_RESPONSE_v2.pdf` for the per-finding rationale.

Source-tree access for the reviewer

The full v2.0.0 source tree is at <https://github.com/Portwood-Global-Solutions/DocGen> (release tag `v2.0.0`, commit `d41503f` is the released-package source — every later commit is documentation only). The repo is public; no clone credentials needed. Helpful entry points:

- `docs/appexchange/v2.0.0/` — every form-field response + every uploaded attachment (.md sources + .pdf renderings)
- `SECURITY_REVIEW_RESPONSE_v2.md` — per-finding map of the v1.56 review
- `CLAUDE.md` — engineering invariants and release validation checklist
- `force-app/main/default/classes/DocGenSignatureGuestSecurity.cls` — new v2.0 helper class (class-level javadoc documents the full guest security model)
- `scripts/e2e-*.apex` — 11 end-to-end anonymous Apex scripts run on every release

Contact during review

- **Primary contact:** Dave Moudy — dave@portwood.dev
 - **Response SLA:** within 24 hours during US business hours
 - **GitHub issue tracker:** <https://github.com/Portwood-Global-Solutions/DocGen/issues> (public; reviewer may file findings here or via the Partner Console directly)
 - **Security disclosure policy:** `SECURITY.md` at the repo root
-

Word count

~990 words. The Partner Console “Other Information” field accepts long technical text; this is structured so a reviewer can skim the headers and zoom into whichever scenario or known-limit they need.

File maintained at docs/appexchange/v2.0.0/

Listing_Other_Information.md so future re-submissions can pull this verbatim or update in place.